Unité 10 — Taint, risque & CVSS

Livrable B — Support de cours · UE « Software Security »

Code UE 7532 14 U32 D1 · 11 octobre 2026

> **Place dans le programme.** « Identifier menaces et vecteurs », « évaluer les risques associés, leur gravité et leur exploitabilité ». On relie les vulnérabilités étudiées à une démarche d'évaluation du risque : **analyse de teinte** (taint), classification **CWE**, identifiants **CVE**, scoring **CVSS**, registre de risques. *Taint analysis issue de meltypot (source/sink/sanitiser + exemple tracé) ; CWE/CVE/CVSS et registre = contenu auteur.*

1. Analyse de teinte (taint analysis)

Idée : marquer comme « teintée » toute donnée issue d'une **source** (entrée utilisateur) et suivre sa **propagation** jusqu'aux **sinks** dangereux (`execute`, `system`, écriture HTML...). Si une donnée teintée atteint un sink sans passer par un **assainisseur**, on lève une alerte.

SCHÉMA — SOURCE → PROPAGATION → SINK (MELTYPOT)

```
SOURCE                PROPAGATION                SINK
request.args["q"]  ->  s = "...%s..." % q    ->   render(s)       (XSS)
(teinte)               (teinte propagee)           (teinte @ sink : ALERTE)
```

Exemple tracé (meltypot, « dynamic taint at runtime ») : un *shadow store* associe à chaque variable un bit de teinte, propagé à chaque affectation ; l'arrivée d'une valeur teintée à un sink déclenche l'alerte. C'est le fondement théorique du repérage d'injections (U7/U8) et de nombreux SAST (U9).

2. CWE — classer le type de faille

La **CWE** (Common Weakness Enumeration) est un catalogue de *types* de faiblesses. Elle donne un vocabulaire commun :

CWE	Faiblesse	Vu en
CWE-121/122	Débordement de tampon (pile/tas)	U2, U3
CWE-416 / 415	Use-after-free / double-free	U3
CWE-89	Injection SQL	U7
CWE-78 / 22 / 79	Injection de commande / traversée / XSS	U8
CWE-190 / 457	Dépassement d'entier / variable non initialisée	U5, U3

3. CVE — identifier une vulnérabilité concrète

Un **CVE** (Common Vulnerabilities and Exposures) est un identifiant unique d'une vulnérabilité *précise* dans un produit donné (ex. Heartbleed = CVE-2014-0160). CWE = *type* ; CVE = *instance*.

4. CVSS — mesurer la gravité

Le **CVSS** v3.1 produit un score 0–10 à partir d'un **vecteur** de métriques de base : vecteur d'attaque (AV), complexité (AC), privilèges requis (PR), interaction (UI), portée (S), impacts confidentialité/intégrité/disponibilité (C/I/A). Scores **réels** calculés pour les vulnérabilités des labos :

CVSS V3.1 — SCORES CALCULÉS (BIBLIOTHÈQUE CVSS)

```
SQLi (contournement d'auth)   AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N -> 9.1  (Critical)
Debordement de pile -> RCE    AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H -> 9.8  (Critical)
Traversee de chemin (lecture) AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N -> 7.5  (High)
XSS reflechi                  AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N -> 6.1  (Medium)
```

Lecture : le débordement menant à l'exécution de code (9.8) prime sur la lecture seule par traversée (7.5), elle-même au-dessus du XSS réfléchi (6.1, car il exige une interaction et n'a qu'un impact partiel).

5. Du score au registre de risques

Le **risque** combine la gravité (CVSS) et la **probabilité/exploitabilité** (facilité d'exploitation, exposition, existence d'exploits publics). Un **registre de risques** liste chaque vulnérabilité avec : description, CWE, CVSS, exploitabilité, actif touché, traitement (corriger/atténuer/accepter), échéance, responsable.

6. Points clés

- La teinte relie formellement sources et sinks : socle du repérage d'injections.
- CWE = type, CVE = instance, CVSS = gravité chiffrée.
- Le risque = gravité × exploitabilité ; il se consigne et se priorise.

Taint analysis issue de meltypot ; CWE/CVE/CVSS/registre auteur ; scores CVSS calculés (bibliothèque cvss).